

25. Zabezpečení webových aplikací - SQL injection, XSS, CS

Základ

- Nidky nevěřit uživatelskému vstupu
- Zranitelnosti aplikace jsou tam, kde nejsou ohlídané všechny možné možnosti

SQL injection

- Útok na databázi
- Princip: vložení škodlivého SQL kódu do vstupního pole, pokud je poté vstup s kódem předložen databázi, tak ho vykoná
- Příklad: kód - *SELECT * FROM users WHERE jmeno = '\$vstup'*, útočník do vstupu zadá *admin' OR '1'='1'*, výsledný dotaz co se pošle do databáze je tedy *SELECT * FROM users WHERE jmeno = 'admin' OR '1'='1'*. *1=1* vždy tudíž se bez hesla dostaneme kamkoliv
- Dopady: možnost přístupu kohokoliv k celé databázi, tzn. krádež dat, smazání dat, neoprávněné přihlášení do app
- Jak se bránit: Prepared statements – data a dotaz se do databáze pošlou odděleně, db s daty zachází striktně jako s textem, některé moderní frameworky dělají toto automaticky použitím ORM

XSS – Cross-Site Scripting

- Útok na prohlížeč uživatele
- Princip: vložení na zranitelný web JavaScript kód, např. do komentáře, uživatel tento komentář poté otevře a jeho prohlížeč automaticky JS kód provede
- Typy:
 - stored – nejnebezpečnější, uložen někde v db např v tom komentáři, zasáhne každého návštěvníka
 - reflected – kód součástí URL adresy, např v emailu
- Dopady: skript může ukrást Session Cookies uživateli z prohlížeče a odeslat je útočnickovi zpět (krádež přihlášení)
- Obrana: Sanitizace/Escapování výstupu – Převod nebezpečných znaků na neškodné HTML entity, HttpOnly Cookies – Příznak u cookies, zakazující js jejich použití

CSRF - Cross-Site Request Forgery

- Princip: použití toho, že prohlížeš automaticky posílá cookies, na nějakém webu může útočník dát element se skrytým odkazem na např. banku a převod peněz, pokud uživatel je zrovna přihlášený a cookie by byla nazebezpečená, může se hacker tímto způsobem dostat k přihlášeným webům
- Obrana:
 - Anti-CSRF Tokeny: Server do každého formuláře (např. pro změnu hesla) přidá skryté pole s unikátním kódem. Útočník na svém falešném webu tento kód nezná, takže banka požadavek zamítne
 - SameSite Cookie Atribut: Moderní obrana v prohlížečích (hodnota Strict nebo Lax), která říká, že cookie se nesmí odeslat, pokud požadavek přišel z cizí domény